

Technology Comparison: QR vs RFID vs NFC

Standalone extract of the Phase 1 report

CSE 347/652 | DES 306/525 Usable Security and Privacy
IIIT-Delhi · Monsoon 2026 · Instructor: Dr. Arun Balaji Buduru

Phase 1: User Studies to evolve Requirements, Design and Workflows
Submission: 4 October 2026

Team: [INSERT TEAM MEMBER NAMES AND ROLL NUMBERS]

Primary research status: instruments complete; fieldwork data not yet collected. All placeholders are marked [DATA REQUIRED]. No primary data has been fabricated.

13. Technology Comparison: QR vs RFID vs NFC

All entries are [SECONDARY] or (inference). "RFID" is split into the two classes that matter, because lumping them together produces misleading conclusions. Ratings: ● strong / favourable, ◐ moderate / conditional, ○ weak / unfavourable.

Criterion	Static QR (printed or fixed image)	Dynamic signed QR (app-generated)	LF RFID 125 kHz (fixed UID)	HF RFID / smart card, ISO 14443 with AES challenge–response	NFC phone credential (card emulation)
Authentication strength	○ Static secret; equivalent to a printed password [21]	● Signed, time-bound assertion; single-factor unless app requires unlock [37, 40]	○ Identification only; UID is the credential [31, 32]	● Cryptographic possession proof with per-card key [2, 41]	● Cryptographic possession proof; phone unlock adds second factor [1]
Credential cloning	○ Photograph it	● Key is in phone; clone requires extracting key from device	○ Seconds with cheap writer [32]	● Depends on chip: Classic/iCLASS broken [4–6]; DESFire EV3/Plus EV2 no public break [41]; side channels possible [7]	● Hardware-backed keys resist extraction; malware on rooted device is a risk
Replay risk	○ Indefinite replay	● Replay limited to validity window (30–60 s); real-time relay still possible	○ Indefinite replay	● Challenge–response defeats replay; relay possible [18–20]	● Same as smart card; relay possible [20]
Physical security of credential	○ Visible to bystanders on card/screen	● On screen briefly; shoulder-surf within window	○ Card readable at distance up to ~10 cm, sometimes more with large antennas	● Card readable at ~4–10 cm; skimming yields nothing useful without key	● Credential inactive until phone unlocked
Cost (per credential)	● Near zero (print)	● Near zero if student owns phone	● Low	● Moderate (secure smart card blank + personalisation)	● Near zero if phone owned; ○ excludes students without compatible phone
Cost (reader)	● Camera on tablet/phone	● Camera	● Low	● Moderate; SAM or secure key storage in reader raises cost	● Same reader as smart card
Speed at gate	● Unlock, open app, aim; glare-sensitive	● Same as static	● Tap, <1 s	● Tap, <1 s including crypto	● Tap; may need unlock first (~1–3 s)
Usability	● Familiar; requires two hands and attention	● Familiar; requires attention	● No attention required	● No attention required; card must be retrieved (H1)	● Phone usually already in hand; ○ battery dependence
Accessibility	○ Requires vision to aim; fine motor control	○ Same	● Works through wallet/bag; no vision needed	● Same; tactile/audio reader feedback possible	● Phone accessibility features apply; still requires holding device
Privacy	○ Static code is a persistent identifier readable by anyone	● Content rotates; identifier can be pseudonymous	○ Fixed UID is trackable by any reader in range	● Random UID mode available on modern chips [41]; protocol can avoid leaking identity before authentication	● Platform-dependent UID randomisation; app can enforce pseudonymity
Offline capability	● Reader can verify locally if it has a list	● Signature verification is fully offline; revocation list needed	● Local list	● Local key + signed revocation list	● Same
Reliability	● Camera, lighting, screen condition	● Same plus app and battery	● Very reliable	● Very reliable	● Phone OS updates, battery, app state
Scalability	●	●	●	●	●
Ease of implementation (Phase 2)	● Trivial	● Standard libraries (Ed25519, TOTP)	● Trivial	● Needs card SDK, key personalisation, SAM handling	○ Platform card-emulation constraints; Android HCE feasible, iOS restricted
Security limitations	Copy = compromise	Relay; phone malware; time sync	Copy = compromise	Relay; chip-family break; key management	Relay; device compromise; platform lock-in
User acceptance	[DATA REQUIRED] Q16	[DATA REQUIRED] Q16	[DATA REQUIRED] Q16	[DATA REQUIRED] Q16	[DATA REQUIRED] Q16, Q17

13.1 Analysis

Two of the five options fail the security requirements outright and are excluded as a sole credential: static QR and LF 125 kHz RFID both expose a static secret that is the credential, so a single capture equals permanent compromise. This is not a matter of degree; it is the same failure that the hotel-lock cases [8, 9] and MIFARE Classic [4, 5] exhibit.

The remaining three are all viable and have complementary weaknesses:

- AES smart card: strongest against cloning and replay, most reliable, most accessible, fastest, and works for every student regardless of phone. Weaknesses: card must be carried and retrieved (the very friction H1 hypothesises), it is single-factor, and a lost card is a usable credential until revoked.

- NFC phone credential: adds a second factor (phone unlock), students already carry phones, and lost-device risk is lower. Weaknesses: excludes students without a compatible phone (A3), depends on battery and OS, and iOS card emulation is not generally available to third-party apps, which constrains Phase 2.
- Dynamic signed QR: works on any smartphone including those without NFC, is cheap to implement, and is fully verifiable offline. Weaknesses: slower and more error-prone at the gate, replayable within its window, and least accessible.

13.2 Provisional direction

Hybrid, with the smart card as the universal baseline.

1. Primary credential: an ISO/IEC 14443 smart card with AES challenge–response (DESFire EV3 / Plus EV2 class [41]) issued to every student. This guarantees universality (no phone required), speed and accessibility, and meets SEC-01/04/14 by design.
2. Optional phone credential: students who opt in may enrol a phone credential that is either NFC card emulation (where the platform allows) or a dynamic signed QR generated by the app. Both are bound to the same identity and subject to the same authorization and revocation. The phone path exists to reduce H1 friction and to give a fallback when the card is forgotten (Section 32: forgotten-ID workflow uses the phone credential, not a bypass).
3. Visitor credential: a time-bound, single-purpose signed QR code issued on host approval, displayed on the visitor's phone or printed at the gate. Visitors do not receive smart cards.
4. Human check retained: on every authenticated tap the guard's screen shows the photo on file for the authenticated credential; the guard confirms the face. This is the mitigation for relay and for borrowed credentials, which cryptography cannot address (Section 24).

Why not phone-only? Because A3 is unverified and because excluding students without a compatible phone violates the accessibility objective. Why not card-only? Because it does not address the forgotten-card case without an insecure bypass, and because it is single-factor. Why not QR as primary? Because it is the slowest and least accessible at the gate and is replayable within its window.

This direction is provisional. It will be revisited when Q16 (preference), Q17 (phone capability), Q18 (accessibility) and observation timings are available. The decision is recorded as D1 in Section 34 with the evidence column marked **[DATA REQUIRED]**.

42. References

Numbering is fixed; all in-text citations use these numbers.

Standards and government sources

- [1] NIST. SP 800-63-4: Digital Identity Guidelines (with 800-63A-4 Identity Proofing, 800-63B-4 Authentication and Authenticator Management, 800-63C-4 Federation). National Institute of Standards and Technology, July 2025. <https://csrc.nist.gov/pubs/sp/800/63/4/final>
- [2] NIST. SP 800-116 Rev. 1: Guidelines for the Use of PIV Credentials in Facility Access. National Institute of Standards and Technology, June 2018. <https://csrc.nist.gov/pubs/sp/800/116/r1/final>
- [3] NIST. SP 800-57 Part 1 Rev. 5: Recommendation for Key Management. National Institute of Standards and Technology, May 2020.
- [4] F. D. Garcia, G. de Koning Gans, R. Muijters, P. van Rossum, R. Verdult, R. Wichers Schreur, B. Jacobs. "Dismantling MIFARE Classic." ESORICS 2008, LNCS 5283, Springer, pp. 97–114.
- [5] K. Nohl, D. Evans, Starbug, H. Plötz. "Reverse-Engineering a Cryptographic RFID Tag." USENIX Security Symposium 2008, pp. 185–193.
- [6] F. D. Garcia, G. de Koning Gans, R. Verdult, M. Meriac. "Dismantling iClass and iClass Elite." ESORICS 2012, LNCS 7459, Springer, pp. 697–715.
- [7] D. Oswald, C. Paar. "Breaking Mifare DESFire MF3ICD40: Power Analysis and Templates in the Real World." CHES 2011, LNCS 6917, Springer, pp. 207–222.
- [8] T. Tuominen, T. Hirvonen. "Ghost in the Locks" (Vision by VingCard vulnerability disclosure). F-Secure, April 2018. Reported in: A. Greenberg, "A One-Minute Attack Let Hackers Spoof Hotel Master Keys," Wired, 25 Apr 2018.
- [9] L. Wouters, I. Carroll, et al. "Unsaflok: Security vulnerabilities in dormakaba Saflok hotel locks." Disclosure site, March 2024. <https://unsaflok.com/>. Reported in Ars Technica, 21 Mar 2024.
- [10] A. Adams, M. A. Sasse. "Users Are Not the Enemy." Communications of the ACM 42(12), 1999, pp. 40–46.
- [11] C. Herley. "So Long, and No Thanks for the Externalities: The Rational Rejection of Security Advice by Users." NSPW 2009, ACM, pp. 133–144.
- [12] A. Whitten, J. D. Tygar. "Why Johnny Can't Encrypt: A Usability Evaluation of PGP 5.0." USENIX Security Symposium 1999.
- [13] K.-P. Yee. "User Interaction Design for Secure Systems." ICICS 2002, LNCS 2513, Springer, pp. 278–290.
- [14] J. H. Saltzer, M. D. Schroeder. "The Protection of Information in Computer Systems." Proceedings of the IEEE 63(9), 1975, pp. 1278–1308.
- [15] J. Nielsen. "Enhancing the Explanatory Power of Usability Heuristics." CHI 1994, ACM, pp. 152–158. Updated as "10 Usability Heuristics for User Interface Design," Nielsen Norman Group.
- [16] L. F. Cranor. "A Framework for Reasoning About the Human in the Loop." UPSEC 2008, USENIX.
- [17] A. Beutement, M. A. Sasse, M. Wonham. "The Compliance Budget: Managing Security Behaviour in Organisations." NSPW 2008, ACM, pp. 47–58.
- [18] G. P. Hancke, M. G. Kuhn. "An RFID Distance Bounding Protocol." SecureComm 2005, IEEE, pp. 67–73.
- [19] A. Francillon, B. Danev, S. Capkun. "Relay Attacks on Passive Keyless Entry and Start Systems in Modern Cars." NDSS 2011, Internet Society.
- [20] L. Francis, G. Hancke, K. Mayes, K. Markantonakis. "Practical NFC Peer-to-Peer Relay Attack Using Mobile Phones." RFIDSec 2010, LNCS 6370, Springer, pp. 35–49.
- [21] K. Krombholz, P. Frühwirth, P. Kieseberg, I. Kapsalis, M. Huber, E. Weippl. "QR Code Security: A Survey of Attacks and Challenges for Usable Security." HAS 2014 (HCI International), LNCS 8533, Springer, pp. 79–90.
- [22] Government of India. The Digital Personal Data Protection Act, 2023 (No. 22 of 2023). Gazette of India, 11 August 2023.
- [23] ISO/IEC 14443-1:2018 to 14443-4:2018. Cards and security devices for personal identification — Contactless proximity objects. International Organization for Standardization.

- [24] ISO/IEC 18092:2023. Information technology — Telecommunications and information exchange between systems — Near Field Communication Interface and Protocol (NFCIP-1).
- [25] ISO/IEC 18004:2024. Information technology — Automatic identification and data capture techniques — QR Code bar code symbology specification.
- [26] ISO/IEC 29100:2024. Information technology — Security techniques — Privacy framework.
- [27] A. Cavoukian. Privacy by Design: The 7 Foundational Principles. Information and Privacy Commissioner of Ontario, 2009 (rev. 2011).
- [28] W3C. Web Content Accessibility Guidelines (WCAG) 2.2. W3C Recommendation, 5 October 2023.
- [29] OWASP Foundation. Application Security Verification Standard (ASVS) 4.0.3, 2021; and OWASP Logging Cheat Sheet.
- [30] A. Shostack. Threat Modeling: Designing for Security. Wiley, 2014.
- [31] R. Anderson. Security Engineering: A Guide to Building Dependable Distributed Systems, 3rd ed. Wiley, 2020. (Ch. 13 "Physical Tamper Resistance", Ch. 16 "Physical Protection".)
- [32] R. Verdult. The (in)security of proprietary cryptography. PhD thesis, Radboud University Nijmegen / KU Leuven, 2015.
- [33] J. Bonneau, C. Herley, P. C. van Oorschot, F. Stajano. "The Quest to Replace Passwords: A Framework for Comparative Evaluation of Web Authentication Schemes." IEEE Symposium on Security and Privacy 2012, pp. 553–567.
- [34] S. Garfinkel, H. R. Lipford. Usable Security: History, Themes, and Challenges. Morgan & Claypool, 2014.
- [35] Apple Inc. "Apple adds support for contactless student ID cards in Wallet." Apple Newsroom, 2 October 2018; and "Apple brings contactless student IDs on iPhone and Apple Watch to more universities," 13 August 2019.
- [36] C. Brocius. "My Arduino can beat up your hotel room lock." Black Hat USA 2012 (Onity HT lock vulnerability).
- [37] D. M'Raihi, S. Machani, M. Pei, J. Rydell. RFC 6238: TOTP: Time-Based One-Time Password Algorithm. IETF, May 2011.
- [38] S. Josefsson, I. Liusvaara. RFC 8032: Edwards-Curve Digital Signature Algorithm (EdDSA). IETF, January 2017.
- [39] E. Rescorla. RFC 8446: The Transport Layer Security (TLS) Protocol Version 1.3. IETF, August 2018.
- [40] M. Jones, J. Bradley, N. Sakimura. RFC 7519: JSON Web Token (JWT). IETF, May 2015.
- [41] NXP Semiconductors. MIFARE DESFire EV3 contactless multi-application IC (product data sheet, AES-128 mutual authentication); MIFARE Plus EV2 product data sheet. NXP, 2020–2022.
- [42] M. A. Sasse, S. Brostoff, D. Weirich. "Transforming the 'Weakest Link' — a Human/Computer Interaction Approach to Usable and Effective Security." BT Technology Journal 19(3), 2001, pp. 122–131.
- [43] IIIT-Delhi. Course Project Guidelines, CSE 347/652 | DES 306/525 Usable Security and Privacy, Monsoon 2026 (Dr. Arun Balaji Buduru). Course handout.

Note on source quality. Sources [8], [9] and [36] are security-conference or vendor disclosures rather than peer-reviewed papers; they are cited for the existence and nature of a publicly demonstrated attack, with the primary disclosure named and a reputable secondary report given. Vendor data sheets [41] are cited only for the cryptographic primitives a product family claims to implement, not for security assurance. Source [35] is cited only for the fact that named universities offer NFC student credentials in Apple Wallet, as stated by Apple; it is not cited as evidence of security properties.